

SIMATS ENGINEERING

ASSESSMENT TOOL 3

COURSE CODE: CSA5113

COURSE NAME: Cryptography and Network Security

COURSE OUTCOME COVERED

CO5: *Develop the network security strategies based on the study of viruses, worms, firewall architectures, and IDS/IPS functionalities.CO (BL5, BL6)*

Assessment Tool Weightage: 10%

**QUESTIONS: 20 TOTAL MARKS: 20 Annexure A
MOCK INTERVIEW**

Code of Conduct:

I DINDU PUJITHA(192373037) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: D PUJITHA

Annexure A

MOCK INTERVIEW

1. **Analyze the weaknesses of SSL and explain why TLS is considered more secure in modern web systems.**

Answer:

SSL has several weaknesses, including outdated cryptographic algorithms, weak cipher suites, and vulnerabilities such as POODLE. SSL also has weaker protection against modern attacks. TLS improves security by supporting stronger encryption algorithms, better authentication, improved key exchange, and stronger integrity protection. Therefore, modern web systems use TLS instead of SSL.

2. **Apply the TLS handshake process to explain how secure session keys are established between a client and server.**

Answer:

The TLS handshake establishes a secure connection between a client and server:

- Client sends **ClientHello** with supported TLS versions and cipher suites.
- Server responds with **ServerHello** and selects security parameters.
- Server sends its **digital certificate** for authentication.
- Client verifies the certificate.
- Client and server perform a secure key-exchange process.
- Both independently derive the same **session key**.
- The session key is then used for encrypted communication.

3. **Compare SSL and TLS in terms of encryption mechanisms and identify key improvements in TLS.**

Answer:

SSL vs TLS

Feature	SSL	TLS
Security	Older and weaker	More secure

Encryption	Older/weak algorithms supported	Stronger algorithms
Authentication	Basic certificate authentication	Improved authentication
Integrity	Older mechanisms	Stronger integrity protection
Key exchange	Deprecated	Widely used
Modern use	Older methods	Improved secure key exchange

4. Evaluate a scenario where improper certificate validation in TLS leads to a security breach. What could go wrong?

Answer:

Improper certificate validation

Suppose a user connects to an online banking website, but the application does not properly verify the server certificate. An attacker could present a fake certificate and perform a **man-in-the-middle attack**. The attacker could intercept usernames, passwords, session information, or sensitive transactions. Proper certificate-chain, hostname, validity, and trust verification prevents this type of attack.

5. Analyze the role of digital certificates in SSL/TLS and explain how they ensure authentication.

Answer:

Role of digital certificates

Digital certificates bind a website's identity to its **public key**. They are issued and digitally signed by trusted Certificate Authorities (CAs). During TLS, the client verifies the certificate's validity, issuer, hostname, and signature. If verification succeeds, the client can trust that it is communicating with the intended server.

6. Apply your understanding of SET protocol to explain how it protects credit card transactions in e-commerce.

Answer:

SET protocol and e-commerce transactions

Secure Electronic Transaction (SET) was designed to protect credit-card transactions over the Internet. It uses:

- Digital certificates for authentication.
- Encryption to protect payment information.
- Digital signatures for transaction integrity.
- Separation of order information from payment information.

The merchant can verify the transaction without directly receiving the customer's complete card details.

7. Evaluate the limitations of the SET protocol in current online payment systems.

Answer:

Limitations of SET today

SET has several limitations:

- Complex implementation.
- Requires digital certificates for participants.
- High deployment and management cost.
- Difficult for ordinary users to configure.
- Requires participation from multiple parties.
- Modern payment systems provide simpler alternatives.

Therefore, SET is rarely used in modern online payment systems.

8. Compare SET protocol with TLS-based payment security and justify which is more practical today.

Answer:

SET vs TLS-based payment security

Feature	SET	TLS-based security
Complexity	High	Lower
Certificates	Required for multiple participants	Mainly server authentication
Deployment	Difficult	Easy and widespread
User experience	Complex	Simple
Modern adoption	Very limited	Very common

9. Analyze a malware attack scenario and differentiate whether it is caused by a virus, worm, or Trojan.

Answer:

Malware scenario: virus, worm, or Trojan

Suppose an employee downloads a program that appears to be legitimate software. After installation, it secretly gives an attacker access to the computer.

This is a **Trojan** because the malware disguises itself as legitimate software and relies on user interaction for installation.

- **Virus:** attaches to files and spreads when infected files are executed.
- **Worm:** independently spreads across networks.
- **Trojan:** disguises itself as legitimate software.

10. Apply appropriate mitigation techniques for a worm attack spreading across a corporate network.

Answer:

Mitigating a worm attack

For a worm spreading through a corporate network:

- Isolate infected systems.
- Block malicious IP addresses and ports using firewalls.
- Patch vulnerable operating systems and applications.
- Update antivirus/endpoint security software.
- Use IDS/IPS to detect and block suspicious traffic.
- Segment the corporate network.
- Monitor network traffic.
- Restore affected systems after removing the worm.

11. Evaluate the impact of Trojan attacks on system confidentiality and integrity with an example scenario.

Answer:

Trojan impact on confidentiality and integrity

A Trojan can secretly provide attackers with unauthorized access. For example, an employee installs a fake accounting application. The Trojan records login credentials and modifies financial files.

Confidentiality impact: passwords and sensitive information can be stolen.

Integrity impact: files, databases, or transactions can be modified without authorization.

Thus, Trojans can cause both data theft and unauthorized modification.

12.Compare viruses, worms, and Trojans based on propagation method and system impact.

Answer:

Virus vs Worm vs Trojan

Feature	Virus	Worm	Trojan
Propagation	Infects files	Self-spreads through networks	Usually requires user installation
User interaction	Often required	Usually not required	Usually required
Main impact	File/system damage	Rapid network infection	Unauthorized access/data theft
Self-replication	Yes, through infected files	Yes	Generally no
Example behavior	Infects executable files	Spreads between computers	Fake legitimate application

13.Analyze the working of a packet-filtering firewall and identify its limitations in modern networks.

Answer:

Packet-filtering firewall

A packet-filtering firewall examines packet information such as:

- Source IP address
- Destination IP address
- Port number
- Protocol

It compares these values with predefined rules and either allows or blocks the packet.

Limitations:

- Does not understand application-level content deeply.
- Stateless filtering does not track connections.

- Difficult to manage large rule sets.
- Cannot effectively detect sophisticated application attacks.
- Can be bypassed using certain advanced techniques.

14. Apply firewall rules to block unauthorized access while allowing legitimate traffic in a given scenario.

Answer:

Firewall rules scenario

Suppose a company wants to:

- Allow HTTPS web traffic.
- Allow DNS.
- Block unauthorized external access to an internal server.

Example rules:

ALLOW TCP destination-port 443

ALLOW UDP destination-port 53

ALLOW TCP destination-port 80

BLOCK TCP destination-port 22 from unauthorized networks

BLOCK all other unauthorized incoming traffic

The firewall processes packets according to these rules and allows legitimate services while blocking unauthorized access.

15. Evaluate the effectiveness of stateful inspection firewalls over stateless firewalls.

Answer:

Stateful vs stateless firewall

Stateless firewall:

- Examines each packet independently.
- Uses predefined rules.
- Does not remember connection state.

Stateful firewall:

- Maintains a state table.
- Tracks active connections.
- Understands whether packets belong to legitimate sessions.
- Provides better control over traffic.

Therefore, **stateful inspection is generally more effective** because it can distinguish legitimate established connections from unexpected traffic.

16.Compare different types of firewalls and recommend the most suitable one for an enterprise network.

Answer:

Types of firewalls and recommendation

Common firewall types include:

1. Packet-filtering firewall
2. Stateful inspection firewall
3. Proxy/application firewall
4. Next-Generation Firewall (NGFW)

For an enterprise network, an **NGFW** is generally the most suitable because it can combine stateful inspection with application awareness, intrusion prevention, user-based controls, and other advanced security features.

17.Analyze how an IDS detects malicious activities using signature-based and anomaly-based techniques.

Answer:

IDS detection techniques

Signature-based detection:

- Compares network activity with known attack signatures.
- Effective for known threats.
- Produces fewer false positives for recognized attacks.
- Cannot easily detect completely new attacks.

Anomaly-based detection:

- Establishes a baseline of normal behavior.
- Detects significant deviations from that baseline.
- Can identify previously unknown attacks.
- May generate more false positives.

Using both techniques provides broader detection capability.

18. Apply IDS/IPS mechanisms to prevent a distributed denial-of-service (DDoS) attack.

Answer:

IDS/IPS against DDoS

For a DDoS attack:

1. IDS monitors network traffic.
2. It identifies unusual traffic volume or known attack patterns.
3. IDS generates an alert.
4. IPS can automatically block or rate-limit suspicious traffic.
5. Firewall rules can block malicious sources.
6. Network traffic can be filtered and rate-limited.
7. Legitimate traffic is allowed to continue.

For large-scale DDoS attacks, additional upstream/cloud-based DDoS protection may also be required.

19. Evaluate the differences between IDS and IPS in terms of response to detected threats.

Answer:

IDS vs IPS

Feature	IDS	IPS
Meaning	Intrusion Detection System	Intrusion Prevention System
Monitoring	Yes	Yes

Detection	Yes	Yes
Response	Generates alerts/logs	Automatically blocks/prevents
Network position	Usually monitors traffic	Usually placed inline
Main purpose	Detect threats	Detect and stop threats

20. Propose improvements to reduce false positives in an IDS while maintaining high detection accuracy.

Answer:

Reducing IDS false positives

To reduce false positives while maintaining accuracy:

- Improve the normal-traffic baseline.
- Regularly update attack signatures.
- Tune detection thresholds.
- Combine signature and anomaly detection.
- Use contextual information such as user, device, and network location.
- Whitelist trusted activities carefully.
- Correlate alerts from multiple security sources.
- Continuously analyze and tune rules based on real incidents.

This helps the IDS focus on genuinely suspicious activity without significantly reducing its ability to detect attacks.